

Lotery

Lotery.sol | Solidity ^0.8.20 | OWASP SC Top 10 2026 + SWC Registry

60

RISK SCORE / 100

1. Identificacion del contrato

Proposito	Loteria: los jugadores compran tickets con ETH y se sortea un ganador.
Actores	Jugadores (buyTickets), quien llame drawWinner (cualquiera).
Flujo de fondos	ETH entra por buyTickets()/receive(); no hay pago de premio (sin salida de fondos).

2-4. Hallazgos: clasificacion OWASP / SWC y vector de ataque

#	Riesgo / Causa raiz	Descripcion y vector de ataque	Sev.	SWC	OWASP 2026
1	Aleatoriedad controlada por el llamante Root: Ausencia de fuente de entropia segura (p.ej. VRF); la 'aleatoriedad' es un input externo.	drawWinner(uint256 randomness) usa un parametro suministrado por quien llama como unica fuente de azar; el resultado es totalmente predecible y elegible. Vector: El atacante calcula el randomness que selecciona su propia direccion como ganadora.	High	SWC-120	SC02:2026 Business Logic Errors
2	Sin pago de premio: fondos bloqueados Root: Falta logica de distribucion del premio.	drawWinner es view y solo devuelve una direccion; no transfiere el bote al ganador. No hay funcion que pague. El ETH queda congelado. Vector: Bloqueo permanente del bote acumulado.	High	SWC-105	SC02:2026 Business Logic Errors
3	Peso de tickets inconsistente Root: Modelo de probabilidad mal implementado.	buyTickets hace un unico players.push por llamada aunque se compren varios tickets; el peso real difiere del conteo en tickets[]. poolWeight usa el balance, mezclando unidades. Vector: Distribucion injusta de probabilidades respecto a los tickets pagados.	Medium	N/A	SC02:2026 Business Logic Errors

3. Analisis de logica de negocio

La loteria no es ni justa ni funcional: el ganador es manipulable y nunca cobra; los fondos quedan atrapados.

6. Benchmark metrics

3 Total	0 Critical	2 High	1 Medium	0 Low	0.90 Confidence	0.88 Precision	1.00 Coverage	50 Time (s)	60 Risk
------------	---------------	-----------	-------------	----------	--------------------	-------------------	------------------	----------------	------------

Severidad: Critical / High / Medium / Low. Metricas Precision/Coverage/Confidence estimadas (0-1). Risk score agregado por severidad (0-100). Analisis estatico manual; sin ground truth provisto (Gold Standard: N/A).